

RAPPORT D'AUDIT DE CONFORMITÉ RGPD

Module M108 : Gouvernance et Protection des Données

****Réalisé par**** : Imrane Assafni

****Groupe**** : ID104

****Date**** : Juin 2026

1. Cartographie et Analyse des Données Collectées

* ****a. Données Identifiées sur la Plateforme : ****

La plateforme collecte des données d'identification directe (****Nom, Prénom, E-mail, Téléphone, Date de naissance****), des identifiants nationaux (****Numéro de Sécurité Sociale - NSS****), des données de santé via un ****champ libre****, ainsi que des données de navigation (****IP, Cookies publicitaires via Google Analytics****).

* ****b. Qualification des Données Sensibles : ****

* ****Données de santé**** : Le contenu du champ libre médical est une donnée hautement sensible (Article 9 du RGPD) nécessitant un chiffrement fort et un accès restreint.

* ****Numéro de Sécurité Sociale (NSS)**** : Identifiant pivot national, son exposition présente un risque majeur d'usurpation d'identité.

* ****c. Évaluation du Principe de Minimisation (Article 5.1.c) : ****

****Non-conformité majeure****. La collecte du NSS et des cookies publicitaires n'est pas strictement nécessaire pour une simple prise de rendez-vous médical. De plus, le champ libre non encadré pousse les utilisateurs à divulguer des données de santé excessives.

2. Évaluation des Principes Fondamentaux du RGPD

* ****Principes Violés : ****

1. ****Minimisation des données**** : Collecte excessive de données non justifiées.

2. ****Limitation de la conservation**** : Les données médicales sont conservées indéfiniment sans politique d'archivage.

3. ****Transparence et Licéité**** : Politique de confidentialité obsolète et absence totale de recueil de consentement pour les traceurs.

3. Droits des Personnes Concernées & Procédures de Garantie

* ****a. Droits à Garantir : ****

Droit d'accès, de rectification, d'effacement (droit à l'oubli), de portabilité, d'opposition, et de limitation du traitement.

* **b. Recommandations de Mise en Œuvre :**

* Déploiement d'un **Dashboard Utilisateur** pour permettre l'auto-gestion des droits (Accès et Portabilité).

* Création d'un canal de contact dédié sécurisé (ex: `dpo@medicare.com`) pour centraliser les requêtes.

* Mise en place d'un registre interne pour traiter et répondre aux demandes dans le délai légal d'un mois.

4. Gestion du Consentement et Traceurs (Cookies)

* **a. Conformité Actuelle :**

Non-conforme. Les cookies de Google Analytics et publicitaires sont déposés sans information préalable et sans action positive de l'utilisateur.

* **b. Critères de Validité du Consentement :**

Pour être conforme, le consentement doit être **Libre** (sans chantage au service), **Spécifique** (par finalité), **Éclairé** (transparence totale), **Univoque** (case non pré-cochée) et **Révocable** à tout moment.

5. Plan d'Action & Recommandations Prioritaires

1. ****Implémentation d'une CMP (Cookie Management Platform)**** : Bloquer les scripts Analytics/Publicitaires avant le consentement explicite.
2. ****Politique de Rétention des Données**** : Définir des durées de conservation légales et automatiser la purge ou l'anonymisation des dossiers inactifs.
3. ****Refonte de la Politique de Confidentialité**** : Mettre à jour les mentions légales, détailler les finalités et nommer un DPO (Data Protection Officer).
4. ****Sécurisation du Champ Libre**** : Remplacer le champ libre par des menus déroulants ou encadrer techniquement la saisie pour éviter la collecte involontaire de données médicales lourdes.